Monthly Intelligence Dispatch

July 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

- Mexico, UAE, Morocco, Saudi Arabia, Bahrain, Hungary, India and other countries allegedly used private Israeli spyware Pegasus designed by NSO Group to tracks journalists, human rights activists, and politicians.French President Emanuel Macron, is among 14 heads of states identified as possible targets.
- **ZeroX** hacker group claims to have attacked a Saudi Arabian oil giant Saudi Aramco.
- WildPressure hacker group uses Milum Trojan to attack industry-related entities in the Middle East.
- Gettr, a pro-Trump social network, created by Jason Miller was hacked on launch day.
- Japanese cyber security software company Trend Micro found new version of XCSSET for macOS Big Sur. The updated malware targets different applications among which Telegram, Chrome, and Skype.
- Phishers target users of BlaBlaCar.
- PetitPotam attack allows to take control of a Windows domain.
- Operation Lyrebird: Group-IB assists INTERPOL in identifying suspect behind numerous cybercrimes worldwide.
- Group-IB helps Dutch police identify and apprehend members of phishing developer gang Fraud Family.

Pegasus

Mexico, UAE, Morocco, Saudi Arabia, Bahrain, Hungary, India and other countries allegedly used private Israeli spyware Pegasus designed by NSO Group to track journalists, human rights activists, and politicians.French President Emanuel Macron, is among 14 heads of states identified as possible targets. According to the analysis done by Amnesty International's Security lab a list of about 50,000 phone numbers was leaked. Some of the number were linked to 600 politicians and government officials and 189 journalists working for The Associated Press, Reuters, CNN, The Wall Street Journal, Le Monde and The Financial Times, 85 human rights activists, 65 business executives, and even several heads of states, including French President Emmanuel Macron. After the scandal, Amazon cloud service shut down NSO Group accounts and their infrastructure.

There are several groups, which use Pegasus not only to track citizens of their country but to spy on the neighbor states. Such actions can be qualified as cyber espionage. NSO Group claims that the software was originally designed to fight terrorism and track criminals, but just like in case of the CobaltStrike penetration testing tool, criminals and APTs start to abuse these solutions. The Pegasus developers have been exploiting vulnerabilities in iOS for a long time. We believe that these vulnerabilities can still be exploited in iOS version 14.6, and even the new BlastDoor sandbox for messages will not solve the problem. For now, there is no information yet that this vulnerability is being exploited by some other cybercriminals, but it is quite possible that this may happen soon.

NSO Group is not the first company to sell spyware. Italian information technology company HackingTeam became known to public after hackers breached the company and made 400 GB of confidential corporate data (agreements, correspondence, and source code) available for download. It turned out that Hacking Team sold spyware to law enforcement agencies and secret services around the world, including Australian police, UAE Ministry of the Interior, National Security Service of Uzbekistan, and the US Department of Defense. Another example is the German FinFisher, which provides "legitimate" spyware for Android, iOS, Windows, macOS, and Linux.

Saudi Aramco

ZeroX hacker group claims to have stolen 1 TB of sensitive data from the Saudi Arabian oil and gas giant Saudi Aramco. According to the threat actor the stolen information includes reports, agreements, correspondence, blueprints, network documents, unit prices, entry points, surveillance data and information about smart devices.

The threat actors are offering the stolen data at an initial price of $5 million. ZeroX does not specialize in ransomware attacks, but the group has been targeting companies to steal their data and sell it. In case of Saudi Aramco, ZeroX demanded $50 million ransom payment for completely removing the stollen information from adversary servers and transferring the data to one source.

Gettr, a pro-Trump social network, created by Jason Miller, former Trump advisor Jason Miller was hacked on day 1. By that time more than 500,000 people have registered to use the site. The attacker defaced the accounts of some prominent republicans, including former United States secretary of state Mike Pompeo, Jason Miller U.S. representative for Georgia's 14th congressional district Marjorie Taylor Greene, and former Trump advisor Steve Bannon. According to The Record, the attacker collected the user data in two batches, on July 1 and July 5, and dumped it on a hacking forum known as RAID. The first batch of the stolen data was collected by web scraping, while the second, and a bulkier leak, which contained information about 90,000 accounts occurred because of a vulnerability.

WildPressure, an advanced persistent threat (APT) uses Milum, a malicious Trojan to target the industrial sector in the Middle East. Researchers discovered the files, which contained the C++ version of the malware, a corresponding Visual Basic Script and another version written in Python. The latter was developed to infect both Windows and macOS systems. All the three versions can collect data about the victim, upload files and execute operator’s commands.

Group-IB warns of a new fraud scheme that uses fake 3-D Secure payment confirmation pages for online purchase. According to experts, the damage caused by this scheme within 6 months in 2021 amounts to more than $5 million.

3-D Secure

By creating phishing sites mimicking popular services and online stores, scammers have learned to make fake payment pages, allegedly protected by 3-D Secure. This technology used to be considered one of the most effective in terms of protecting user payment information related to online purchases around the world. The danger of using fake 3-D Secure pages lies in the fact that they are quite difficult to identify, often times they contain the logos of the international payment systems like Visa and MasterCard and do not cause suspicion among buyers who want to make a quick purchase online. At the same time, the client's payment looks legal for the issuing bank, and in case of complaints, it will be extremely difficult for the client to return the money transferred to the scammers via a fake 3-D Secure page, having confirmed the transaction with a verification code from the SMS.

Group-IB emphasizes that the scheme affected different parties involved in the purchase: the customer, who, most likely lost the money, the issuing bank that approved the transaction, the online marketplace or store, and the payment system, suffering from brand misuse.

REvil

REvil Ransomware Group server and infrastructure is shut down. Bloomberg believes that the shutdown is a result of discussion between President Joe Biden and Russian President Vladimir Putin about curbing attacks against American companies. Revil is considered one of the most aggressive and dangerous threat actors. After hitting Apple supplier Quanta with a ransomware attack, the hackers targeted JBS Foods, a leading global food company and then switched to Sol Oriens, a US nuclear weapons contractor. The hacker group keeps increasing the ransom demands, first they demanded $50 million from Acer, then $70 million from MSP provider Kaseya, while JBS was reported to have paid $11million. There are two main versions of what is going on: REvil decided to get rid of their infrastructure themselves and, perhaps, after a while they will return under a different name and with an updated ransomware, or maybe the law enforcement agencies contributed to the shutdown of adversary infrastructure. Recently, REvil has carried out several significant attacks against Acer, Honeywell and Kaseya, in addition, the meetings between the heads of Russia and the United States could also push law enforcement agencies or the REvil group to take measures. Moreover, the account of REvil representatives on hacker forums was blocked by the administration, it is a common practice when the owner of the malware runs the risk of being brought to justice.

BlaBlaCar

Hackers attacked marketplace for carpooling BlaBlaCar. According to Group-IB's experts, the number of phishing sites mimicking the service has grown by 67% within a month, today there are more then 300 of them on the Internet. During the pandemic, such means of transportation became preferable for many people since it involves interaction with fewer people than going somewhere by bus or train. Comfort attracts users and phishers usually come after them. The cybercriminals trick users of the resource into making a prepayment for the trip by sending fake links through third-party instant messengers. When users make a payment via a fake resource, they not only transfer money to cybercriminals, but also leave personal information that can later be used for criminal purposes. BlaBlaCar said that the service is actively fighting the criminals.

Group-IB's **Digital Risk Protection team** analyzed the main types of online frauds associated with the COVID-19 pandemic. As of early July, the first place was occupied by the sale of fake vaccination certificates on underground forums, in Telegram channels and social networks (the cost of a certificate including entry to the register of vaccinated people varied from $40 to $400). Then go the fake results of PCR tests and antibody tests (the price varies from $7 to $55). The third place goes to the recently canceled QR codes for visiting restaurants and cafes (estimated cost from $14 to $41).

Instagram

CERT-GIB discovered an unusual scheme that targets users of popular social networks. The fraudster creates a private Instagram account, for example, of a pretty girl, and posts a link to "pages" in other social networks in the profile. The "girl" behaves in a provocative manner insulting and humiliating other users. As a rule, victims of bullying try to "learn more" about the cyberbully and go to the profile of the "girl" and, failing to find any useful information they click on the link specified in the profile and find themselves on a phishing site that mimics popular social networks. If the victim enters their username and password, the fraudster gains control over the account. According to Group-IB, 268 fake Instagram profiles were registered in 2021, 37 of which were registered in July.

LemonDuck

Microsoft warns of **LemonDuck** malware targeting Windows and Linux systems. The malware continues to evolve and now it can bypass security solutions and erase its traces. Mining is the main objective of the malware, **LemonDuck** diverts the computing resources to illegally mine cryptocurrency; aggressive use of processing power may be a sign of **LemonDuck** in the system," says Roman Rezvukhin, Acting Deputy Head of Malware Analysis at Group-IB. There is one more indicator of the malicious activity — an outgoing connection to the mining pools. According to the expert, the danger of **LemonDuck** lies in the fact that the developers are gradually expanding the set of techniques used to gain initial access to compromised systems and add new capabilities to their tools. For example, downloading additional malware, which can lead to repeated and more serious compromise of the corporate networks. "Since **LemonDuck** is spread using phishing, various exploits, and brute-force of publicly available services, the best way to prevent it from spreading at the initial stages is to timely install updates, carry out audit and infrastructure inventory, and use technologies designed to prevent targeted attacks," said Rezvukhin.

French security researcher Gilles Lionel identified a bug tied to the Windows OS and called it PetitPotam. The vulnerability makes it possible to force remote Windows systems to authenticate a threat actor and share its authentication details via NTLMS or authentication certificates. According to Lionel, the bug allows to abuse a remote access protocol MS-EFSRPC (function EfsRpcOpenFileRaw) designed to allow Windows systems to access remote encrypted data stores. This type of attack is relevant for large corporate networks, where they can lead to a complete compromise of the company's internal network. Microsoft published guidelines to help ensure protection against such attacks (for example, disable NTLM unless needed, and enable Extended Protection for Authentication).

Researchers from Japanese cyber security software company Trend Micro found a new version of XCSSET, which was used to perform attacks against macOS software developers. The updated malware can now steal information from different applications among which Telegram, Chrome, Opera, and Skype. To propagate XCSSET, attackers inject malicious code into local Xcode projects for developing macOS software. The malware starts functioning immediately when the project is compiled.

Arrests and sentences

Fraud Family

Group-IB's threat research center in Amsterdam assisted the Dutch National Police to apprehend alleged members of a cybercriminal group codenamed Fraud Family. Operation resulted in the arrest of two suspects, a 24-year-old man and his 15-year-old accomplice, who are thought to be the developer and seller of the phishing malware. In 2020, Group-IB's Threat Intelligence team has registered large-scale phishing attacks on residents of the Netherlands and Belgium. The fake pages were mimicking the resources of large European banks and used them to collect bank card data. A typical attack, analyzed by Group-IB researchers, started with an email, SMS, or WhatsApp message impersonating a real financial organization; it contained a request to follow a link, as a result, the victim was directed to phishing resources. After blocking dangerous content, Group-IB specialists examined the cybercriminals' infrastructure in detail and tracked down a criminal group operating according to the Fraud-as-a-Service scheme. The hacker group, codenamed Fraud Family, developed, sold and leased phishing kits (constructors for phishing resources) and administrative web panels that allowed them to manage phishing sites in real time. To advertise their service, the attackers actively used Telegram in their activity, about 2,000 people were subscribed to their channels.

Lyrebird

Group-IB assisted Interpol in its Lyrebird operation, which resulted in the identification and apprehension of a criminal dubbed **DrHeX** in Morocco. The criminal has been active since 2009 and is responsible for phishing, deface, malware development, fraud and bank card data theft. Group-IB began the investigation when Group-IB Threat Intelligence & Attribution detected a phishing kit aimed at mass creation of phishing sites, which was used to attack a large French bank. Using its patented graph network analysis technology, Group-IB researchers built a network graph based on the email address from the phishing kit. A total of five email addresses associated with the criminal were detected along with six nicknames and the accounts in Skype, Facebook, Instagram, and Youtube. Further analysis of Dr Hex's digital footprint revealed its connection to other crimes. The data was transferred to Interpol and led to further arrest of the criminal.

Forecasts and warnings

- “Legitimate" spyware has always been in demand, and the cyber-weapon business will continue to prosper until strict legal restrictions up to a moratorium will be introduced. So far, after another episode of the spyware scandal, the Amazon cloud service shut down the accounts and IT infrastructure of the NSO Group. This was destined to happen because back in 2020 it became known that the phone number of the Amazon founder, billionaire Jeff Bezos, was hacked with the help of malicious software from the NSO Group.
- Almost 64% of all ransomware attacks analyzed by Group-IB in 2020 were carried out by ransomware operators using the Ransomware-as-a-Service (RaaS) model. The developers sell or let their partners rent the malware to further hack the network and deploy ransomware.
- In order to avoid the sad fate of Saudi Aramco, pay attention to Group-IB Threat Hunting Framework Industrial (https://www.group-ib.ru/threat-hunting-framework.html), a unified autonomous platform that ensures end-to-end protection for the entire enterprise including industrial and IT networks, as well as workplaces, against complex cyber attacks such as sabotage and espionage by pro-government hacker groups (APT), and against financially motivated cybercriminals, including #1 cyberthreat, ransomware.
- Since LemonDuck is spread using phishing, various exploits, and brute-force of publicly available services, the best way to prevent it from spreading at the initial stages is to timely install updates, carry out audit and inventory of infrastructure, use technologies designed to prevent targeted attacks.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+1 917 809 47 41
+7 495 984 33 64
intelligence@group-ib.com